

10 обязательных шагов; новый — правила работы с ИИ	≈ 150 ч часов человека до альфы (было 290); до выпуска 0.1 ≈ 200 ч	2,5–5 мес. до альфы при 20 или 10 ч/нед.; предел — проверка, не написание	≈ \$1–2 тыс. сертификат, домен, подписка на ИИ-агента
---	---	--	--

#	ЭТАП	НЕД.*	Ч.Ч.	ИИ-АГЕНТ ДЕЛАЕТ	ЧЕЛОВЕК ДЕЛАЕТ (НЕ ДЕЛЕГИРУЕТСЯ)	КОНТРОЛЬНАЯ ТОЧКА
0	Право и решения обязательно	0–2	10	Черновик соглашения (готов); проверка названия; сравнение Go и .NET; черновик правил работы с ИИ	Подписать соглашение; выбрать язык; решить управление проектом и реестр РФ; заказать сертификат в первый день	К0: письмо подписано, имя чисто, сертификат заказан, правила ИИ приняты. До К0 — ни одного публичного коммита.
1	Каталог проверок v1 обязательно	1–3	25	≈ 50 проверок из первичных источников со ссылками; валидатор имён атрибутов и флагов по схеме Microsoft; тексты «почему / как эксплуатируется / как исправить» EN/RU	Подтвердить каждую проверку по источнику (20–30 мин); отбраковать выдуманные атрибуты; не допускать код PingCastle и Purple Knight в контекст агента	К1: каталог в репозитории раньше кода; у каждой проверки — источник, подтверждённый человеком.
2	Репозиторий и конвейер обязательно	1–3	15	Скелет репозитория; CONTRIBUTING с чистой комнатой и раскрытием ИИ-вклада; CI: сборка на трёх ОС, подпись, SBOM, provenance, тест «только чтение», лаборатория Samba, сканер сходства	Создать организацию и зеркало; ключи и секреты (агент их не видит); проверить, что конвейер блокирует выпуск при любом сбое	К2: пустой подписанный бинарник проходит все ворота на трёх ОС; сканер сходства включён.
3	Движок и провайдер AD обязательно	3–7	50	LDAP и Kerberos, снимки, 25 проверок уровня 0 с тестами на синтетике, отчёт, doctor, консоль; второй агент рецензирует код первого	Утвердить архитектуру; построчно читать точки доверия (аутентификация, подпись пакетов, «только чтение»); отладить на живом AD — Kerberos и подпись LDAP агент без домена не отладит	К3: быстрый скан лабораторного домена ≤ 5 мин без настроек, в том числе на «ужесточённом» контроллере.
4	Веб-мастер и экспресс-путь обязательно	6–9	20	Семь экранов, «Сканировать», живой ход, --demo, обезличивание, честные состояния; тесты на XSS враждебными значениями	Пройти путь глазами администратора на Windows и Linux; решить спорное в интерфейсе; подтвердить замеры	К4: три действия и ≤ 5 мин до отчёта измеряются в CI на каждом выпуске.
5	Пакет для согласования, упаковка до выпуска	8–10	15	Генераторы пакета в CI (модель угроз, сетевые взаимодействия, манифест запросов, инструкция для SOC, персональные данные); MSI, .deb, .rpm; скрипт учётной записи аудита; тексты заявок в белые списки	Дать пакет на прочтение знакомому специалисту по ИБ; исправить; подать заявки в белые списки от своего имени	К5: выпуск блокируется, если в пакете не хватает хотя бы одного артефакта.
6	Закрытая альфа обязательно	10–13	30	Разбор обезличенных снимков и журналов, воспроизведение на синтетике, исправления с тестами, черновики ответов пилотам	Найти 5–10 пилотных доменов и вести общение; решать спорные срабатывания; подключить второго сопровождающего; данные пилотов — только обезличенными	К6: ноль инцидентов на боевых доменах, ≥ 3 развёрнутых отзыва, ложные срабатывания закрыты.
7	Публичный выпуск 0.1 обязательно	13–15	15	Документация EN/RU, образец отчёта, README «почему бесплатно», черновики статьи на Хабр и англоязычной публикации, манифесты winget и Homebrew	Переписать публикации своим голосом; выпустить сборки; отвечать первым пользователям	К7: подписанные сборки на трёх ОС, пакет для согласования опубликован.
8	После выпуска по ситуации	15+	—	Сортировка обращений, исправления, новые проверки, FreeIPA / ALD Pro, Entra ID, fix --plan, расписание и сравнение запусков	Приоритеты; приём вкладов с раскрытием ИИ-участия; независимый аудит; решения о платной поддержке	Отдельная точка на каждый пункт.

ПРАВИЛА РАБОТЫ С ИИ

- Чистая комната для агента. Код PingCastle, Purple Knight и других проектов с ограничивающими лицензиями в контекст не попадает; агент работает по каталогу и первичным источникам; весь код — через сканер сходства.
- Данные. В облачный ИИ — только синтетика и лаборатория; реальные снимки — обезличенными или в локальную модель; секреты агент не видит.
- Судья — CI. Критерии и ворота меняет только человек; «тесты прошли» подтверждает конвейер, а не агент.
- Бюджет на чтение. Движок маленький; точки доверия человек читает построчно, остальное — агент-рецензент. ИИ-вклад помечен в коммитах.

ДЕСЯТЬ ОБЯЗАТЕЛЬНЫХ ШАГОВ

- Согласие работодателя о границе ИС.
 - Чистое название.
 - Сертификат с немедленной репутацией.
 - Правила работы с ИИ и сканер сходства кода.
 - Каталог раньше кода, каждая проверка подтверждена человеком.
 - Конвейер: сборка, подпись, SBOM, ворота.
 - Движок AD, отлаженный на живом домене.
 - Веб-мастер, экспресс-путь ≤ 5 мин.
 - Пакет для согласования из CI.
 - Закрытая альфа на чужих доменах.
- Что ИИ не ускоряет: подписи и решения, ожидание сертификата, отладку на живых доменах, пилотов и их SOC, доверие сообщества — поэтому срок сжимается вдвое, а не впятеро.

РИСКИ ИИ И ОТВЕТЫ

- Чужой код в выдаче модели → сканер сходства, чистая комната, чтение точек доверия человеком.
- Выдуманные атрибуты и флаги → валидатор по схеме Microsoft, тесты на лаборатории, источник у каждой проверки.
- Код пишется быстрее, чем читается → бюджет размера движка, декларативные пакеты, агент-рецензент.
- Утечка данных пилотов → обезличивание по умолчанию, локальная модель, запрет в правилах.
- Ложная уверенность «всё работает» → решают CI и живой домен.